

ביקורת מערכת מקיפה

Orly Medical — מנהל אירוע רפואי

מאי 2026 | 11.05.2026

72	12	18	30	12
סה"כ ממצאים	קריטיים	גבוהים	בינוניים	נמוכים

תקציר מנהלים

במקביל. הביקורת כיסתה חמישה תחומים: אבטחה, UX ונגישות, ארכיטקטורת Backend, איכות Frontend ומוכנות לייצור. בוצעה ביקורת מקיפה של מערכת Orly Medical על ידי חמישה agents מקצועיים שפעלו עם משתמשים בודדים. לפני פתיחה ללקוחות אמיתיים נדרשים תיקונים קריטיים בהגנת נתונים, ניטור שגיאות וגיבויים. ציון כולל: 3.3 מתוך 10 — המערכת מתאימה לסביבת staging

ציון	תחום
5.5 / 10	אבטחה
6.5 / 10	ונגישות UX
6.0 / 10	ארכיטקטורת Backend
6.0 / 10	איכות Frontend
3.3 / 10	מוכנות לייצור

פרק א — ביקורת אבטחה

קריטי

1. ערך ברירת מחדל ל-JWT Secret

שורה 12 — [backend/auth.py](#)

בקוד עצמו כ-fallback. כל מי שרואה את ה-repository יכול לזייף JWT tokens ולהתחזות לכל משתמש, כולל אדמין. ה-SECRET_KEY מוגדר

המלצה

הטל RuntimeError אם SECRET_KEY לא מוגדר כמשתנה סביבה בעת הפעלה.

המפתח הנוכחי ב-Railway תקין — יש לוודא שלא תוחלף ל-default בשום מקרה.

קריטי

2. קודי 2FA ואיפוס סיסמה — קצרים מדי

שורות 164, 190 — [backend/routes/auth.py](#)

הקוד משתמש ב-(token_hex3) — רק 16 מיליון אפשרויות. תקיפת brute-force בקצב נמוך יכולה לנחש קוד תוך שעות.

המלצה

עדכן ל-2 — token_urlsaf(32) בחזקת 256 אפשרויות.

הוסף rate limiting של 3 ניסיונות בלבד לכל 5 דקות על verify-2fa.

גבוה

3. Account Lockout אין

שורות 92–106 — [backend/routes/auth.py](#)

אין נעילת חשבון לאחר ניסיונות התחברות כושלים. Rate limiting לפי IP בלבד — ניתן לעקוף עם רשתות proxy.

המלצה

נעל חשבון 15 דקות לאחר 5 ניסיונות כושלים.

שלח הודעת דוא"ל למשתמש על כל ניסיון חריג.

גבוה

4. View Tokens בזיכרון בלבד

שורה 14 — [backend/routes/documents.py](#)

של השרת. לא ניתן לביקורת, לא עמיד לקריסות restart בזיכרון התהליך. הולך לאיבוד בכל dict הוא _VIEW_TOKENS.

המלצה

מגרט ל-DocumentViewToken DB table: עם שדות token, expires_at, is_used, created_by.

גבוה

5. Family Share — אין לוג ביטול

שורות 43–70 — [backend/routes/family_share.py](#)

כשמבטלים קישור לבן משפחה אין רישום של מי ביטל ומתי.
אין שדות revoked_at ו-revoked_by ב-FamilyShareToken.

המלצה

הוסף שדות ביטול ל-FamilyShareToken.
רשום את פעולת הביטול ב-audit log.

גבוה

6. CORS HTTP שיטות —

שורה 106 — [backend/main.py](#)

מתקבלים ממקורות מורשים header וכל HTTP כל שיטת wildcard-מוגדרים allow_headers ו-allow_methods.

המלצה

הגדר רשימה מפורשת: GET, POST, PUT, DELETE בלבד.
הגדר headers מפורשים: Content-Type, Authorization בלבד.

בינוני

7. Audit Log של 2 endpoints לא מכסה —

שורה 14 — [backend/auditmiddleware.py](#)

הנתיבים verify-2fa, forgot-password ו-reset-password אינם מתועדים. ניסיונות תקיפה לא יירשמו בלוג הביקורת.

ביטוי	8. File Upload — MIME bypass
	שורה 109 — backend/routes/documents.py הוא None, בדיקת MIME מדולגת. Magic bytes נבדקים תמיד — אך עדיף לדחות קבצים ללא content-type מפורש. אם content_type
נמוך	9. User-Agent — 200 תווים
	שורה 90 — backend/audit_middleware.py מודרני יכול להיות ארוך מ-200 תווים — המידע נקטע User-Agent. שנה ל-500 תווים.

פרק ב — ביקורת UX ונגישות

ציון WCAG AA: 6.5/10 | ציון IS 5568 (נגישות ישראלית): 5/10

גבוה

10. ניגודיות — צבעי טקסט בהירים על רקע לבן

שורות 244, 298–300 — PatientSummary.jsx

נמוך מ-4.5:1 contrast ratio — על רקע לבן text-slate-400 ו-text-slate-500. תאריכים, קטגוריות ומידע קריטי אינם קריאים דיים לאנשים עם ראייה מוגבלת. תקן WCAG AA דורש יחס ניגודיות של 4.5:1 לפחות לטקסט רגיל.

המלצה

החלף text-slate-500/400 ב-text-slate-700 בכל תוכן קריטי.

גבוה

11. כפתורים — גובה לא עקבי

שורה 81 — PatientSummary.jsx

כפתור 'חזרה לדף הבית' מוגדר עם 1-py בלבד — גובה ~24px. תקן WCAG דורש שטח לחיצה מינימלי של 44px לכל ממד.

המלצה

הוסף min-h-[44px] על כל כפתורים אינטראקטיביים בפורטל המטופל.

גבוה

12. טקסט קטן בניווט תחתון

שורה 859 — PatientSummary.jsx

תוויות הניווט התחתון מוגדרות עם text-xs — קטן מדי לאנשים מבוגרים. מינימום מומלץ לתוכן ניווט: text-sm.

המלצה

שנה ל-text-sm בניווט התחתון של פורטל המטופל.

גבוה

13. חוסר בחלק מהמודלים RTL

ורכיבים נוספים [ManagerLayout.jsx](#)

חלק מהמודלים והדרייברים לא מגדירים `dir=rtl` בשורש שלהם.
רכיבים מקבלים כיוון LTR מברירת מחדל של הדפדפן.

המלצה

כל modal root וכל drawer חייבים `dir=rtl` מפורש.

בינוני

14. Loading States — לא עקביים

[ManagerDashboard.jsx](#), [PatientDetail.jsx](#), [MyDay.jsx](#)

חלק מהדפים מציגים 'טוען...' כטקסט פשוט, חלקם spinner, חלקם ריק לחלוטין.
חוסר עקביות ויזואלית פוגע באמון המשתמש.

המלצה

צור [Skeleton.jsx](#) מרכזי עם animation ו-Tailwind.

השתמש בו בכל מקומות הטעינה באחידות.

בינוני

15. תקן IS 5568 חסר — תקן aria-label

[IntakeWizard.jsx](#), [PatientDetail.jsx](#)

תקן IS 5568 דורש `aria-label` על כל שדה מורכב.
לא בוצע על אף רכיב במערכת Screen reader testing.
שדות תאריך מורכבים (DateSegment) אינם נגישים לקוראי מסך.

המלצה

הוסף `aria-label` לכל שדה קלט מורכב.

בצע בדיקת screen reader לפחות על פורטל המטופל.

נקודות חיוביות בפורטל המטופל	נמוך
□ PatientSummary.jsx מוגדר — מרווח שורות מיטבי לעברית [1.8]-leading כפתור עזרה '?' קבוע בפינה — פעיל ומתאים לדף. כפתור קריאה קולית (Web Speech API) — ייחודי ונגיש. לניווט מובייל — נכון ונוח BottomNav מצב פשוט (SimpleContext) — מפחית עומס קוגניטיבי.	

פרק ג — ביקורת ארכיטקטורת Backend

קריטי

17. SQLite ללא WAL Mode

שורות 6–12 — [backend/database.py](#)

בהגדרות ברירת מחדל חוסם קריאות בזמן כתיבה SQLite ב-production עם מספר workers — כל כתיבה גורמת ל-timeout לכל שאר הבקשות. בשרת Railway שמריץ מספר threads — זה מתרחש בכל פעולת שמירה.

המלצה

הוסף `PRAGMA journal_mode=WAL` ב-`connect event`.
לטווח בינוני: הגר ל-`PostgreSQL managed` שמציע Railway.

קריטי

18. N+1 Queries משימות

שורות 51–76 — [backend/routes/tasks.py](#)

נפרד לכל מטופל לכל סוג נתון query שולחת `_sync_tasks_for_manager()` עם 50 מטופלים: `queries + 200` לכל בקשה לדף 'היום שלי'. בזמן peak usage — המערכת תאט משמעותית.

המלצה

שימוש ב-`joinedload()` ו-`selectinload()` מ-`SQLAlchemy`.
אפשרות חלופית: `batch load` כל הנתונים בשאילתה אחת עם `IN clause`.

גבוה

שגיאות נבלעות בשקט — 19. flow_engine

שורות 46, 52, 91 — [backend/flow_engine.py](#)

שלושה בלוקי `except Exception: pass` בחישוב כיסוי ביטוחי. שגיאות קריטיות בחישוב לא מוצגות ולא נרשמות. המנהל לא יודע שחישוב הכיסוי נכשל.

המלצה

החלף כל `except: pass` ב-`logger.exception()`.
הוסף הודעת שגיאה ב-`response` כשחישוב נכשל.

גבוה

אין מגבלת ריצות מקבילות — 20. APScheduler

שורה 60 — [backend/main.py](#)

`max_instances=1` מוגדר ללא `weekly drug update`.
אם `job` קודם עדיין רץ, יתחיל עוד אחד במקביל.
גורם ל-`duplicate drugs` ול-`race conditions` ב-DB.

המלצה

הוסף `max_instances=1` לכל `job` ב-`APScheduler`.

גבוה

חסר תביעות Cascade Delete — 21. Cascade Delete

שורה 358 — [backend/models.py](#)

`Claim.insurance_source_id` ללא `cascade`.
מחיקת `InsuranceSource` משאיר תביעות ייתומות ב-DB.

המלצה

הוסף `cascade=all, delete` לכל `relationship` קריטי.

ביטוי

22. Drug Search — טוען הכל לזיכרון

שורות 64–89 — [backend/routes/medications.py](#)

טוענת את כל 1,162 התרופות לזיכרון בכל בקשת חיפוש `_search_db()`.
יעילות ירודה; עם גידול מאגר — יגרום ל-memory pressure.

המלצה

שנה ל-DB LIKE query עם LIMIT 20.

ביטוי

23. מודל User — חסרים שדות ביקורת

[backend/models.py](#)

אין `last_login` ו-`last_activity` ב-User model.
קשה לזהות חשבונות לא פעילים ולתחקר כניסות.

המלצה

הוסף `last_login: DateTime` ו-`last_activity: DateTime`.
עדכן בכל login ובכל API request מאומת.

נמוך

24. View Token TTL — 90 שניות קצר מדי

שורה 180 — [backend/routes/documents.py](#)

אם PDF reader פותח לאט, ה-token פג לפני שהקובץ נפתח.
גורם ל-UX שגוי — המשתמש רואה שגיאת 401.

המלצה

הגדל ל-300 שניות (5 דקות).

פרק ד — ביקורת איכות Frontend

קריטי

25. אין Error Boundary

□ [frontend/src/App.jsx](#)

אם רכיב React כלשהו זורק exception — הכל קורס.
אין fallback UI. המשתמש רואה דף לבן ריק.
לטיפול בשגיאות componentDidCatch עם Class Component דורש React

המלצה

צור ErrorBoundary component ועטוף כל ProtectedRoute.

קריטי

26. אין 401 Token Expiry — Token Expired שגט

□ [frontend/src/main.jsx](#)

כשה-JWT פג, בקשות API נכשלות בשגט.
המשתמש אינו מנותק, אינו מקבל הודעה, הנתונים לא מתעדכנים.
המשתמש יכול לחשוב שהמערכת עובדת בעוד כל הפעולות נכשלות.

המלצה

הוסף axios interceptor שמטפל ב-401: מנקה localStorage ומפנה לדף הכניסה.

גבוה

27. שגיאות API נבלעות בשגט — 38 מקומות

□ [ManagerDashboard.jsx](#), [AdminPage.jsx](#), [DoctorsDatabase.jsx](#) ועוד

38 מקומות בקוד משתמשים ב-catch שמדפיס ל-console בלבד.
המשתמש לא יודע שפעולה נכשלה — אין הודעת שגיאה.

המלצה

החלף כל console.error { catch { ב-showToast עם הודעה בעברית.

גבוה

28. IntakeWizard — שמירת תרופות שקטה

□ [frontend/src/pages/manager/IntakeWizard.jsx](#) — שורה 662

אם שמירת תרופה ב-API נכשלת, אין הודעה למשתמש.
המשתמש עלול לחשוב שהתרופה נשמרה בעוד לא נשמרה.

המלצה

הוסף toast עם הודעת שגיאה ברורה בכישלון שמירת תרופה.

בינוני

29. formatDate — כפילות בשלושה קבצים

□ [PatientSummary.jsx](#), [MyDay.jsx](#), [DemoPatientPortal.jsx](#)

פונקציית formatDate מוגדרת ומועתקת בשלושה קבצים שונים.
שינוי בפורמט תאריך ידרוש עדכון בכל שלושת המקומות.

המלצה

צור [frontend/src/utils/formatters.js](#) ויצא משם.

נמוך

30. פורטלי דמו — תקינים ומוכנים להצגה

□ [pages/demo/DemoPatientPortal.jsx](#), [DemoBrokerPortal.jsx](#)

נתוני דמו מציאותיים, כל הניווט פעיל — DemoPatientPortal
סטטיסטיקות, רשימת מטופלים, פעילות אחרונה — DemoBrokerPortal
סגול ברור banner, נגיש למנהל-על בלבד — Demo Launcher
מוכנים לשימוש בהצגות ובדמואים.

פרק ה — מוכנות לייצור

ציון מוכנות: 3.3 מתוך 10

קריטי

31. אין גיבוי — סיכון אובדן נתונים מוחלט

□ [Railway Volume / data/medical_event_manager.db](#)

אין backup strategy כלשהי.

אם Railway Volume נפגע — כל נתוני המטופלים, תביעות, מסמכים וביטוחים אבודים לצמיתות.
אין recovery path. אין snapshot. אין export אוטומטי.

המלצה

יישם daily backup job שמעביר DB ל-S3 או Cloudflare R2.
הוסף endpoint אדמין ידני לטריגר backup מיידי.
בדוק תקינות backup אחת לשבוע.

קריטי

32. instances לא מתאים לריבוי — SQLite

□ [backend/database.py](#)

שכותבים בו זמנית processes לא תוכנן לריבוי SQLite.

data corruption ו-write locks בעומס — זה יגרום ל instances יכול להוסיף Railway.
אין WAL mode — כל כתיבה חוסמת את כל הקריאות.

המלצה

הגר ל-Railway — PostgreSQL managed מציע זאת בחינם עד גבול.
לטווח קצר: הפעל WAL mode וודא single-instance.

קריטי

33. אין ניטור שגיאות

□ כל המערכת

אין Sentry, Rollbar או כל כלי ניטור.
 כשהשרת קורס — אין התראה. Logs ב-Railway נשמרים רק 3 ימים.
 בזמן אמת Railway CLI-באמצעות מוצר גישה ל Debug.

המלצה

התקן sentry-sdk והגדר DSN כמשתנה סביבה.
 עלות: חינם עד 5,000 events לחודש.
 זמן הטמעה: 4 שעות.

קריטי

34. Railway Volume — לא מוגדר כ-persistent

□ Railway config

אין railway.toml המגדיר את Volume כ-persistent.
 /data-ולאבד את כל ה container יכול להחליף deploy.
 כל railway up — סיכון אובדן נתונים.

המלצה

הוסף railway.toml עם הגדרת Volume מפורשת.
 בדוק שהגדרת Volume מוצגת ב-Railway Dashboard.

גבוה

35. CORS לא מוגדר לדומיין ייצור CORS

שורות 97–100 — [backend/main.py](#)

כברירת מחדל CORS-אך לא ב Railway-מוגדר ב FRONTEND_ORIGIN
אם frontend עובר ל-Cloudflare / CDN — כל בקשות API ייחסמו.

המלצה

הוסף FRONTEND_ORIGIN לרשימת allowed origins.

בדוק CORS עובד מדומיין ormed.co.il.

גבוה

36. Migrations — אין rollback

שורות 129–265 — [backend/main.py](#)

version tracking ללא Raw SQL עם run_migrations().

שבור schema שנכשל חצי דרך משאיר Migration.

אין מנגנון rollback או history של שינויים.

המלצה

לטווח ארוך: הגר ל-Alembic.

לטווח קצר: הוסף version tracking ו-logger.error בכל כישלון.

בינוני

37. Health Check לא בודק DB

[backend/main.py](#) — endpoint /api/health

קריס SQLite מחזיר 200 גם אם endpoint /api/health.

לא ידע שהשרת אינו מתפקד Railway.

המלצה

הוסף 1 SELECT ל-DB בבדיקת health.

החזר status 503 אם DB לא מגיב.

ביטוי

38. Rate Limiting — כל endpoints לא מכסה כל

□ [backend/routes/documents.py, routes/admin.py](#)

העלאת מסמכים, חיפוש תרופות וייצוא נתונים — ללא rate limit.

מאפשר שימוש לרעה ו-DoS על endpoints כבדים.

המלצה

הגדר rate limit על כל endpoint שעושה עבודה כבדה.

תוכנית פעולה

חודש 1 — ייצוב והגנת נתונים

שבוע ראשון

- הגדר Sentry לניטור שגיאות (4 שעות)
- יישם daily backup ל-S3 (8 שעות)
- הוסף railway.toml עם הגדרת Volume
- הגדר WAL mode ל-SQLite

שבוע שני-שלישי

- הגר ל-PostgreSQL managed ב-Railway
- הוסף 401 interceptor ב-frontend
- הוסף Error Boundary לכל ProtectedRoute
- החלף console.error ב-showToast

שבוע רביעי

- תיקון N+1 queries בסינכרון משימות
- הוסף max_instances ל-APScheduler jobs
- הוסף account lockout לאחר 5 ניסיונות

חודש 2 — שיפורי UX ומשתמשים

שבוע חמישי-שישי

- דשבורד ניהולי — סקירת כל המלווים ועומס תיקים
- מערכת התראות — דדליינים וחידוש ביטוחים

שבוע שביעי-שמיני

- ניהול sessions — מי מחובר כרגע
- הרשאות הורדה גרנולריות
- כבדים endpoints על כל Rate limiting

חודש 3 — פיצ'רים ונגישות

שבוע תשיעי-עשירי

- עורך תבניות Workflow
- תיקוני aria-label — IS 5568 וboundary testing

- אחיד בכל המערכת Skeleton loaders

שבוע אחד-עשר-שנים-עשר

- התראות חכמות — זיהוי פערי ביטוח אוטומטי
- בדיקת ביצועים וייעול
- בדיקה עם משתמשים מעל גיל 65

מה עובד טוב

- מוגדרים ופעילים WebAuthn-דוא"ל ו TOTP — מלא FA עם JWT 2
- SQL injection אין — parameterized queries עם SQLAlchemy-להצפנת סיסמאות ו bcrypt
- מיירט 17 סוגי פעולות ורושם לוג מלא Audit middleware
- Rate limiting מוגדר על endpoints קריטיים עם Railway-aware IP detection
- Security headers — X-Frame-Options, HSTS, Referrer-Policy פעילים
- Magic bytes validation לבדד MIME לקבצים מועלים — מעבר לבדיקת
- לצפייה במסמכים TTL חד-פעמיים עם View tokens
- פורטל מטופל עם 1.8-leading, כפתור עזרה, קריאה קולית ומצב פשוט
- פורטלי דמו (מטופל וברוקר) עם נתוני דמו מציאותיים — מוכנים להצגה
- ICS calendar feed לפי RFC 5545 tasks, workflow-פגישות ו
- מערכת תרופות עם 1,162 תרופות, 842 שמות עבריים וחיפוש חכם
- CLAUDE.md שומר context תיעוד מקיף —

— סיום הדוח —